Tutorial week 1

Background - Solarwinds

The **SolarWinds Supply Chain Attack** occurred in 2020 when hackers compromised SolarWinds' **Orion IT management software**, which is used by thousands of organizations globally to manage their IT infrastructure. The attackers injected malicious code, known as **Sunburst**, into the software update for Orion. When customers downloaded the compromised update, they unknowingly installed the malware, providing hackers with backdoor access to their systems. The attack affected approximately 18,000 SolarWinds customers, including major U.S. federal agencies, Fortune 500 companies, and global corporations. Once inside these networks, the attackers could steal sensitive data and monitor operations.

Why did it happen

The attack exploited vulnerabilities in SolarWinds' software development and distribution processes:

1. **Weak Security Practices**: SolarWinds reportedly had weak internal cybersecurity measures, such as using outdated passwords like "solarwinds123" in some instances.

2. **Targeting Supply Chains**: The attackers leveraged the trust organizations place in third-party vendors like SolarWinds, realizing that compromising a popular software provider could give them access to numerous high-value targets.

The attack is widely attributed to the **Russian state-sponsored group APT29 (Cozy Bear)**, seeking to gather intelligence and sensitive government data.

Business Impact

1. **Reputational Damage**: SolarWinds faced severe reputational harm, as its failure to secure its systems impacted thousands of customers globally.

2. **Financial Losses**: SolarWinds' stock price plummeted, and the company faced shareholder lawsuits alleging negligence. Costs associated with legal fees, investigations, and security upgrades were substantial.

3. **Customer Fallout**: Organizations affected by the breach had to spend significant resources to secure their systems, identify compromised data, and rebuild trust with stakeholders.

4. **Operational Disruption**: The attack disrupted critical U.S. government operations, including departments managing national security and the COVID-19 response.

How did the organization act

1. **Detection**: The breach was discovered months after the initial compromise by cybersecurity firm **FireEye**, which was one of the victims of the attack. FireEye alerted SolarWinds and the broader cybersecurity community.

2. **Response**: SolarWinds cooperated with government authorities and cybersecurity experts to investigate the attack.

3. **Communication**: The company issued public statements acknowledging the breach and informed customers about the compromised software update.

4. **Remediation**: SolarWinds provided a clean version of the Orion software and recommended that customers upgrade immediately to secure their systems.

How could it be prevented

Strengthening Internal Security:

Enforce stronger password policies (e.g., avoid weak credentials like "solarwinds123").

Implement multi-factor authentication (MFA) across all systems and accounts.

Securing the Software Development Lifecycle:

Regularly audit and test software build environments for vulnerabilities.

Use code signing and integrity tools to validate software updates before distribution.

Adopting Zero Trust Architecture:

Require continuous verification of access requests, even from trusted sources.

Limit the scope of access for third-party software and vendors to minimize risk.

Enhanced Monitoring:

Deploy security tools that can detect unusual patterns in network traffic and software behavior.

Regular Backups:

Maintain multiple, secure backups of critical systems to prevent data loss during an attack.

Vendor Risk Management:

Assess cybersecurity practices of third-party vendors regularly and ensure compliance with strict security standards.

Background - WannaCry

The **WannaCry ransomware attack** occurred in May 2017 and spread rapidly across the globe, infecting over 200,000 computers in 150 countries. WannaCry exploited a vulnerability in Microsoft Windows systems known as **EternalBlue**, which had been leaked from the U.S. National Security Agency (NSA). Once installed, WannaCry encrypted files on infected computers and demanded a ransom in Bitcoin (typically $300-$600) to unlock them.The ransomware spread through networks by exploiting unpatched systems and targeting organizations that had not applied the necessary security updates. Victims included hospitals, telecommunications companies, government agencies, and private companies. The UK's **National Health Service (NHS)** was hit particularly hard, causing widespread disruption to healthcare services, including canceled surgeries and delayed treatments.

Why did it happen

1. **Unpatched Systems**: The attack exploited a known vulnerability (MS17-010) in Microsoft's Server Message Block (SMB) protocol. Many organizations had not applied the patch released by Microsoft two months earlier.

2. **Use of Outdated Systems**: Many organizations, including the NHS, were still using outdated operating systems like Windows XP, which were no longer supported with security updates from Microsoft.

3. **EternalBlue Exploit**: The ransomware relied on the EternalBlue exploit, which was developed by the NSA but leaked online by a hacking group called Shadow Brokers.

4. **Rapid Propagation**: The worm-like nature of WannaCry allowed it to spread across networks without user intervention, infecting vulnerable systems at an alarming rate.

Business Impact

Financial Losses:

Global damages were estimated to be $4 billion due to business disruptions, recovery costs, and reputational damage.

Some organizations paid the ransom, though many did not recover their data even after payment.

Operational Disruption:

Critical services like healthcare were severely impacted. The UK's NHS canceled thousands of patient appointments and delayed surgeries due to locked systems.

Organizations faced downtime and productivity loss as they worked to recover.

Reputational Damage:

Public trust was eroded for organizations that failed to protect sensitive data or provide uninterrupted services.

Legal and Regulatory Issues:

Some organizations faced lawsuits and scrutiny for failing to ensure adequate cybersecurity measures, particularly those handling sensitive data (e.g., healthcare and financial sectors).

How did the organization act

Response Efforts: Organizations scrambled to identify compromised systems and isolate them from their networks to prevent further spread.

Many leveraged backups to restore encrypted data, particularly those that had implemented effective disaster recovery plans.

Governments and cybersecurity experts collaborated to mitigate the attack and identify the perpetrators.

Microsoft's Actions: Microsoft quickly released additional patches for older systems like Windows XP, which were no longer officially supported, in an effort to stop the attack.

Public Communication: Some organizations issued public statements acknowledging the attack and provided updates about their recovery efforts.

Governments warned citizens and businesses to update their systems and avoid paying the ransom.

How could it be prevented

Regular System Updates: Applying security patches promptly is critical to closing known vulnerabilities. Microsoft released patches for the SMB vulnerability two months before the attack, but many organizations failed to update their systems.

Upgrade Outdated Software: Organizations should avoid using unsupported operating systems like Windows XP, which do not receive security updates, leaving them vulnerable.

Network Segmentation: Properly segmenting networks can limit the spread of malware within an organization.

Robust Backup Systems: Maintaining secure, offline backups ensures data recovery without paying the ransom.

Employee Training: Educating employees about phishing and social engineering attacks can help prevent malware from entering the system.

Enhanced Security Tools: Use advanced threat detection and anti-malware solutions to identify and block ransomware before it spreads.

Background – NotPetya @ Maersk

NotPetya was a destructive cyberattack that began on June 27, 2017, initially spreading through a compromised update of the Ukrainian M.E.Doc tax software before rapidly affecting organizations worldwide. Although it appeared to be ransomware, it was actually a wiper designed to permanently destroy data and disrupt operations. Major victims included Maersk, Merck, Rosneft, WPP, FedEx/TNT Express, and several Ukrainian government and financial institutions. The attack caused billions in damages and severely impacted global logistics, pharmaceutical production, and corporate networks. Multiple governments later attributed NotPetya to Russia's GRU, specifically the Sandworm unit, describing it as one of the most damaging cyber incidents in history.

Why did it happen

1. The attack wasn't aimed at Maersk, but rather at the entire nation of the Ukraine, to bring the infrastructure down. Maersk was "collateral" damage.
2. Maersk being a company with locations in many countries, this makes Maersk very vulnerable to such kinds of attack. Specifically in countries with tensions to other countries or with other groups.
3. Maers, like any company, was dependent on specific software (in this case ME Doc) required by local conditions. This makes the company vulnerable to supply chain attacks.
4. The level of dependency on IT, contributed to the size of the impact of the incident in Maersk.

How was organisastion attacked

1. **There was a supply chain attack via Intellect Services, the supplier of ME Doc software.**
2. **Malware was pushed via this software to all customers, including Maersk**
3. **Malware used legitimate process, thereby bypassing some scanners for unauthorised software.**
4. **Known vulnerabilities were exploited. Eternal Blue and Eternal Romance.**
5. **Credentials were harvested from other systems via Mimikatz malware. High privileged credentials were stolen.**
6. **Computers being encrypted, with a fake ransomware note showing on the screen.**

How could have it defended itself

1. **Better network segmentation. (the malware spread from Odessa to Copenhagen to all other ports).**
2. **Better patch management (eternal blue was patcheable.)**
3. **Privileged access management (the administrator should not have logged to a normal machine, which would have prevented from the credentials being stolen).**
4. **Legacy IT (Windows 2000 systems were old)**
5. **Red teaming**
6. **Robust back-up & recovery management**

Organisational Impact

1. **Financial losses** are reported at USD 250-300 mln. (revenue loss, customer attrition, capital expenditure on new IT systems, compensation of customers, operational costs, third party claims)
2. **Operational disruption** including Port Paralysis, 76 terminals were shuttered, manual workarounds, data destruction (finding out which container was on which ship).
3. **Reputational damage** : surprisingly, eventually this improved because of the transparency given by the company about the incident.
4. Stakeholder impact: impacting the global supply chains by congesting major ports like Rotterdam / New York. Employee burn out. Investors didn't like the impact on the stock price.

Tutorial week 2

Risk Assessment – AI Agent Copilot

Inherent Risk profile

- The university process large volume of **highly sensitive student, HR and research data** in a collaborative environment. Not designed for AI discovery
- No one fully knows who can see what – **access** governance.
- Rapid **adoption pressure** and productivity will exceed control maturity.

Identify Cyber Risks / Risk Rating

- **Sensitive student or research** information could **leak** as AI can find and combine data swiftly.
- **Penalties or legal trouble** is personal data is handled incorrectly (**GDPR**)
- **Important research or IP** could be exposed to wrong people.
- Damage of **trust** from students, employees, partners and society even.

Risk Treatment

- **Mitigate** using data classification, block high risk data in prompts, monitor and log, train everyone.
- **Mitigate + Transfer** – Clear policies, legal review, accountability between uni and vendor.
- **Reduce** – Limit access to sensitive repos, extra protection.
- **Mitigate** – transparent communication, visible governance, rapid incident response.

Business Justification

- Can lead to fines, lawsuits nad loss of research funds. Prevention is cheaper than crisi mgmt. and media damage.
- Regulator will not accept blaming AI. Leadership proof.
- Research income/partnership depend on confidentiality.
- Trust is critical for attracting students, partners and reputation of the institution.

Risk Assessment – Agentic AI Lecturer

Inherent Risk profile

- Institution will delegate teaching, assessment and academic judgement to autonomous system, directly **affecting credibility.**
- AI decisions are **not yet** institutionally mature.
- University vulnerable to **reputational escalation** if AI behaves unexpectedly.

Identify Cyber Risks / Risk Rating

- AI could teach wrong information **or grade students unfairly.**
- Students might **sue or complain**.
- **Media news** if AI makes a simple mistake.
- If **hacked**, education will be **interrupted**.
- **Dependancy** on one technology supplier.

Risk Treatment

- **Mitigate** – Human oversight, appeal process, regulat quality testing.
- **Mitigate** – explainable, audit trails, ethics governance.
- **Reduce** – phased rollout, clear communication of AI role, crisis plan.
- **Mitgate + Transfer** – strong architecture, monitoring, vendor accountability.
- **Accept** – exit process, periodic evaluations.

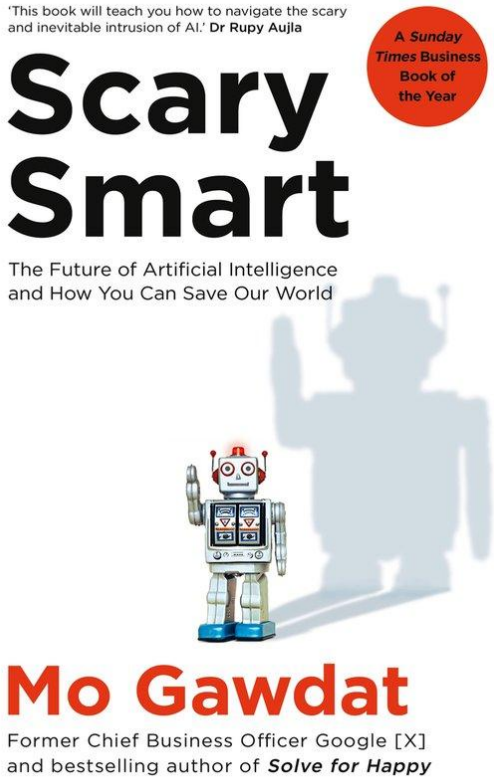
Business Justification

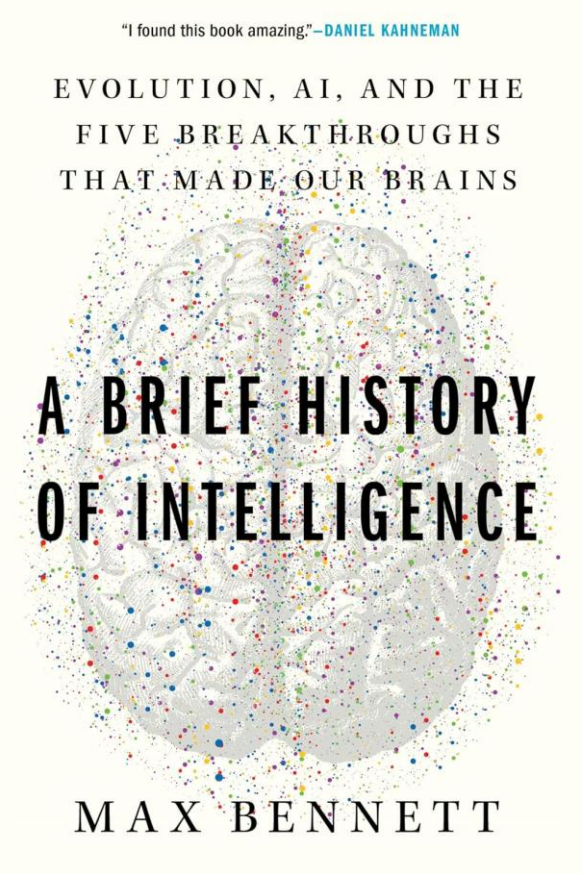
- If grading is questioned, uni loses its value.
- Courst cases and regulator attention would cost far more than controls.
- Public trust takes years to build and minutes to lose.
- Delivery must continue, interruption affects revenue/credibility.
- Innovation is partnership, avoiding dependency stops progress.

Fun facts

Few nice books to read:

- Scary Smart – Mo Gawdat
- A Brief History of Intelligence – Max Bennett





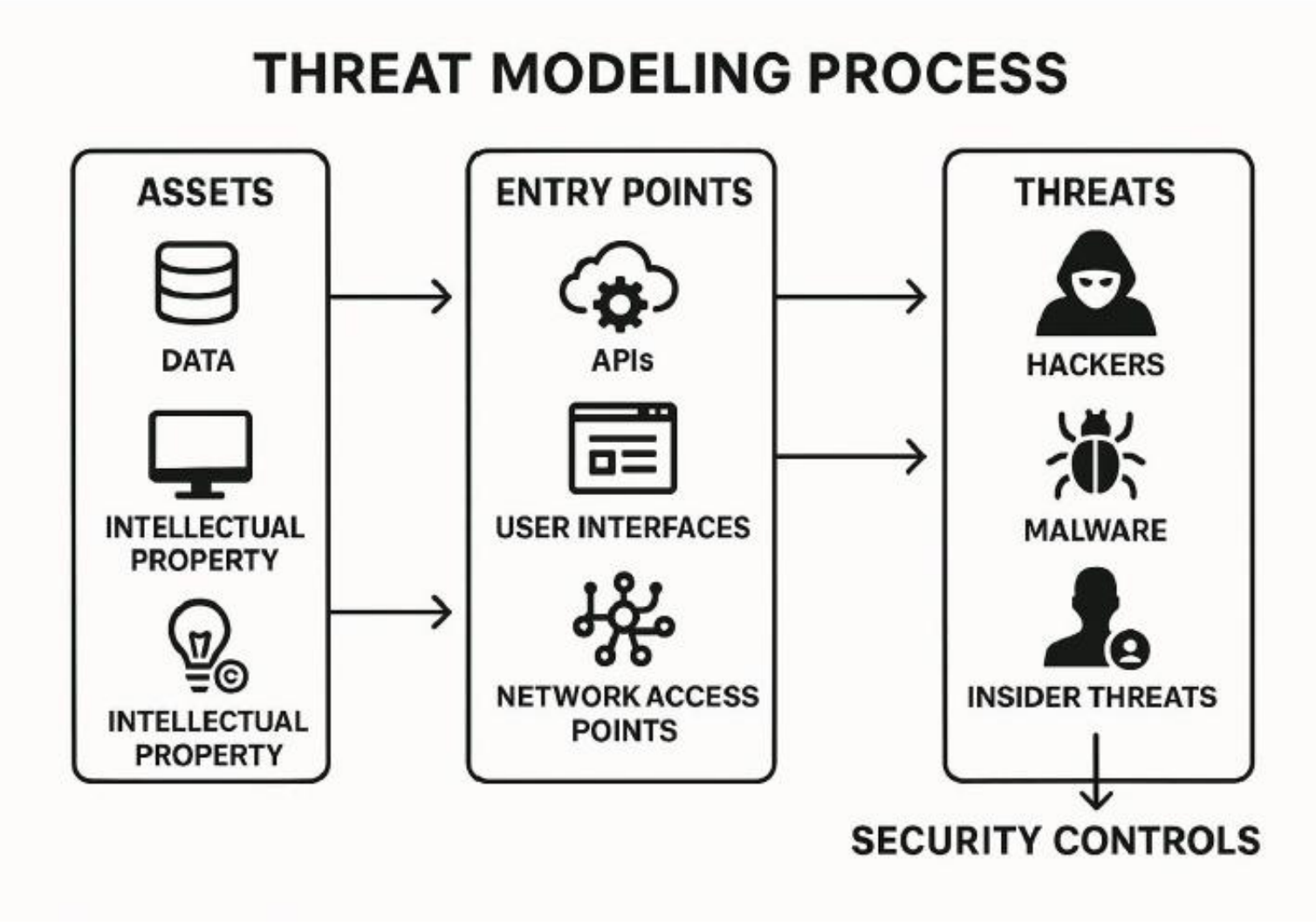
Article Links:

- [Intuit, Uber, and State Farm trial enterprise AI agents]
- [Clawdbot to Moltbot to OpenClaw: The AI agent generating buzz and fear globally]
- [Exploring possible AI trajectories through 2030 (EN)]
- [Github Automation with Mistral AI Agents - Mistral AI Cookbook]

Tutorial week 3

Threat Modeling Process

- What we worry about: threats and vulnerabilities
  - What we care about: assets
  - Controls should protect our assets against threats, to ensure
- The organisations operates within risk appetite.
- We need a strategy to define an effective, proportional control set.



Example – Security Policy

Scope:

This security policy applies to all employees, contractors, and third-party vendors who interact with company systems, networks, and data. The policy governs the classification, handling, and protection of organizational assets, including physical and digital resources, to ensure confidentiality, integrity, and availability.

Enforcement:

Non-compliance with this security policy may result in formally registered deficiencies.

Policy Statements

1. **Asset Classification:**
   All company assets such as applications, infrastructure components including data must be classified based on sensitivity and importance (Confidential, Integrity and Availability).

2. **Access Control:**
   Access to systems and data must be strictly controlled. Employees and contractors should only have access to the resources necessary for their role and responsibilities, following the principle of least privilege.

3. **Authentication Standards:**
   Multi-factor authentication (MFA) must be implemented for access to critical systems and sensitive data. Passwords should meet complexity requirements and be changed regularly.

4. **Data Protection:**
   Sensitive data must be encrypted both in transit and at rest using industry-standard encryption protocols. Access to sensitive data must be logged and monitored.

5. **Physical Security:**
   Access to company facilities and server rooms must be restricted to authorized personnel only. All visitors must sign in and be accompanied by an employee during their visit.

6. **Incident Response:**
   All security incidents must be reported immediately to the designated Security Team. Employees must follow the incident response plan to mitigate threats and preserve evidence.

7. **Device Management:**
   All company devices must have updated antivirus protection, firewalls, and security patches. Personal devices used for work purposes must comply with the company's Bring Your Own Device (BYOD) policy.

8. **Third-Party Vendors:**
   Vendors must adhere to the company's security requirements when accessing systems or handling data. Contracts with third parties should include clauses for data protection and breach notification.

9. **Training and Awareness:**
   Employees must complete mandatory cybersecurity training upon hire and annually thereafter. Regular phishing simulations and awareness campaigns must be conducted.

10. **Monitoring and Auditing:**
    All network activity, system access, and data transactions must be monitored and logged for security purposes. Regular audits must be conducted to ensure compliance with the security policy.

Threat - Phishing

1. **Technical Controls:**
    1. **Email Filtering**: Deploy advanced email filtering systems to detect and block phishing emails automatically.
    2. **Domain Protection**: Implement SPF, DKIM, and DMARC protocols to prevent spoofing of the university's email domain.
    3. **Multi-Factor Authentication (MFA)**: Require MFA for all accounts to prevent unauthorized access even if login credentials are stolen.
    4. **Secure Webpage Design**: Use HTTPS and security certificates to ensure the university's login pages are clearly distinguishable from fake ones.
2. **Organizational Controls:**
    1. **Cybersecurity Awareness Training**: Conduct regular training sessions for students, faculty, and staff to help them recognize phishing attempts.
    2. **Phishing Simulations**: Run periodic phishing simulations to test the community's ability to identify fraudulent emails.
    3. **Incident Response Plan**: Develop and regularly practice a response plan that includes isolating compromised accounts and notifying affected individuals.
3. **Preventive Measures for Students and Faculty:**
    1. **Educate** users to never click on suspicious links or provide credentials without verifying the sender.
    2. **Encourage** reporting of suspected phishing attempts to the university's IT helpdesk.
    3. **Regularly remind** users to check the URL for authenticity (e.g., correct domain and HTTPS).

Example IT Landscape of a University

USERS
- Students
- Faculty
- Researchers
- Admin Staff
- IT Staff
- External Partners

Identity & Access Layer
- Active Directory / Azure AD
- SSO (SAML/OAuth)
- MFA
- Identity Lifecycle Mgmt
- Privileged Access Mgmt

Core Infrastructure
- Campus Network (LAN/WLAN)
- VPN & Firewalls
- Data Centers
- Cloud Platforms (Azure/AWS)
- HPC Clusters
- Research Storage

Core Applications
- LMS (Canvas/Moodle)
- Student Info System
- HR & Finance Systems
- Research Data Platforms
- Document Management

Collaboration Tools
- Microsoft 365
- Teams/Zoom
- Email
- SharePoint/OneDrive

Security Layer
- SIEM/SOC
- Endpoint Detection (EDR)
- Vulnerability Mgmt
- Backup & Recovery
- Incident Response

End-User Devices
- Laptops
- Lab PCs
- Mobile Devices
- Smart Campus Devices

Threat: DDOS Attack on the Bank

1. **Technical Controls:**
    1. **Network Traffic Monitoring and Anomaly Detection -** Implement continuous monitoring of network traffic to detect abnormal spikes or patterns that may indicate a DDoS attack at an early stage.
    2. **Rate Limiting -** Enforce rate-limiting controls on network services to restrict the number of requests a single source can generate, reducing the impact of traffic floods.
    3. **DDoS Mitigation Services -** Use dedicated DDoS protection services (on-premises or cloud-based) that can absorb, filter, or reroute malicious traffic before it reaches critical systems.
    4. **Network Segmentation** - Segment the university network to isolate critical services (e.g. learning platforms, exam systems) so that an attack on one segment does not disrupt all services.
    5. **Redundancy and High Availability Architecture -** Design systems with redundant network paths, load balancing, and failover mechanisms to maintain service availability during high-traffic attacks.

2. **Organizational Controls:**
    1. **DDoS Incident Response Plan -** Establish and maintain a documented DDoS-specific incident response plan, defining roles, escalation paths, communication procedures, and decision-making authority during a network availability incident.
    2. **Clear Roles and Responsibilities** - Assign formal responsibility for DDoS preparedness and response (e.g. IT operations, security team, communications, management), ensuring accountability during an attack.
    3. **Third-Party Coordination Agreements** - Maintain contractual agreements and escalation contacts with ISPs, cloud providers, and DDoS mitigation vendors to ensure rapid coordination during an attack.
    4. **Business Continuity and Availability Planning** - Include DDoS scenarios in the university's business continuity and disaster recovery planning, prioritizing critical services such as learning platforms, exams, and administrative systems.
    5. **Training and Awareness for IT Staff** - Provide regular training and tabletop exercises for IT and security staff to recognize DDoS symptoms, follow response procedures, and coordinate effectively under pressure.

Example IT Landscape of a Bank

USERS
- Retail Customers
- Corporate Clients
- Traders
- Relationship Managers
- Branch Staff
- Call Center Agents
- IT & Security Teams
- Regulators

Identity & Access Layer
- Customer IAM (CIAM)
- Employee IAM (AD/Azure AD)
- SSO / MFA
- Privileged Access Management (PAM)
- IGA – Identity Governance

Core Infrastructure
- Data Centers
- Private / Hybrid Cloud
- Mainframe Systems
- Core Banking Network
- Firewalls / Proxies / DLP
- High Availability Storage

Core Banking & Financial Systems
- Core Banking Platform
- Payments (SEPA/SWIFT)
- Card Processing
- Trading Platforms
- Risk & Compliance Systems
- Treasury Systems

Customer Channels
- Mobile Banking App
- Online Banking Portal
- ATM Network
- Branch Systems
- Call Center Platforms

Collaboration & Workplace Tools
- Microsoft 365
- Email & Teams
- SharePoint / OneDrive
- Case & Workflow Management

Security & Monitoring Layer
- SOC / SIEM
- Threat Intelligence
- EDR/XDR
- Fraud Detection Systems
- Transaction Monitoring
- Backup & DR

End-User Devices
- Workstations
- Secure Laptops
- VDI Desktops
- Mobile Devices
- Secure Terminals

Tutorial week 4

Tutor Cheat Sheet – Case 1

CIA & Operational Impact Understanding

Green flags
- Availability failure to enterprise impact
- IT outage / data breach / data destruction
- Critical assets : AD, ERP, Booking systems, operating systems
- IT outage – operations, revenuw, Legal

Red flags
- Its not just ransomware
- overfocus on C & I of CIA.
- No link between IT assets and business impact

Control Framework Application (NIST CSF / ISO 27k)

Green flags
- Maps Identify, Protect, Detect, Respond, Recover
- Prevention vs resilience
- Business continuity testing

Red flags
- Saying "ISO certified"
- No discussion of recovery capability
- No separation of Operational vs security controls

Governance Model Concepts (Roles, 3 Lines, Accountability)

Green flags
- Board oversight, executive ownership, operational execution
- 1st line –IT ops, 2nd line –Risk/Compliance, 3rd line- Internal Audit
- Identifies who should own resilience

Red flags
- Blaming CISO
- Micromanaging technical recovery
- No clarity on decision authority

Regulatory & Legal Landscape

Green flags
- GDPR breach notification
- NIS /NIS2 implications
- Data breach vs system outage , regulator communication timlines, recognizing state-sponsored attack or not

Red flags
- assuming no data stolen is no regulatory issue
- Ignoring operational resilience expectations
- No discussion on documentation and defensibility

Third-Party & Supply-Chain Risk

Green flags
- Recognizes compromised software update as entry vector
- Vendor due diligence, contractual agreements, concentration risk
- Boarc level oversight of supply chain risk

Red flags
- Treating vendor risk as purely operational
- Np lifecycle view (due diligence->monitporing->exit)

Incident, Evidence & Assurance Concepts

Green flags
- Evidence of preparedness, board reporting cadence, recovery metrics
- How to prove oversight, document decisions ?
- Importanc eof audit trail

Red flags
- One-off reaction with no structural improvement
- No post-crisis lessons captured
- No improvement plan assigned to accountable executive

Tutor Cheat Sheet – Case 2

CIA & Understanding

Green flags

- Correctly applies **Confidentiality, Integrity, Availability** ratings to AI use cases and underlying data/assets
- Identifies relevant **threats** (e.g., model errors, data leakage, third-party exposure) linked to the CIA impact
- Distinguishes **asset criticality** vs generic "important system" claims

Red flags

- Threats listed with no connection to assets or consequences

Control Framework Application (NIST CSF / ISO 27k)

Green flags

- Maps risks/controls to **Identify, Protect, Detect, Respond, Recover** (or equivalent ISO clauses)
- Selects **control intent** appropriate to risk (e.g., monitoring vs hard preventive controls))

Red flags

- Control name-dropping without placement in a framework function
- "We have a policy" treated as proof of effectiveness

Governance Model Concepts (Roles, 3 Lines, Policy Stack)

Green flags

- Explains **governance vs management vs operations** with correct responsibilities
- Places functions within **Three Lines Model** (1st: ownership, 2nd: risk/compliance, 3rd: audit)
- Understands **policy → standard → procedure → guideline** hierarchy and purpose

Red flags

- Policies/standards treated as interchangeable

EU Regulatory Landscape Comprehension

Green flags

- Highlight the relevance of the compliance program as mandatory.
- Make a link with other regulation and see whether these can be combined in the program.

Third-Party & Supply-Chain Risk (incl. AI/Model Providers)

Green flags

- Identifies lifecycle controls for **ICT/AI third parties** (due diligence, contracting, monitoring, exit)
- Connects to DORA/NIS2 expectations for **supplier oversight**

Incident, Evidence & Assurance Concepts

Green flags

- Explains need for **evidence**, metrics, and auditability to demonstrate control **effectiveness**
- Focus on continuous assurance compared to one-off compliance milestones
- Focus on reporting and how to prove effectiveness

Tutorial week 5

Phase 1 – Risk assessment, planning and scoping

- Understanding the business
- Risk assessment
- Scoping the engagement: scope and depth
- Interfaces with other processes and IT systems
- Limited or reasonable assurance?
- Necessary conditions?
- Audit approach?
- Data required, respondents, stakeholders
- Time frame
- Communication plan
- *Agree on engagement with stakeholders*

Phase 2 - Fieldwork and controls testing

- Data analysis
- Reading reports, etc
- Field work
- Interviews with stakeholders
- Observation
- Probing and testing
- Building the audit file: evidence

Phase 3 - Reporting and analysis

- Interview minutes

Figure 1—IT Audit Report Components	
Report Component	**Source**
An appropriate and distinctive title	ITAF
Identification of the recipients to whom the report is directed	ITAF
Identification of the responsible party	ITAF
Table of contents	*IS Audit Reporting*
Introduction	*IS Audit Reporting*
Description of the scope of the audit engagement	ITAF
A statement identifying the source of management's representation about the effectiveness of control procedures	ITAF
A statement that professionals have conducted the audit engagement to express an opinion on the effectiveness of control procedures	ITAF
Identification of the purpose (objectives) of the audit	ITAF
Description of the criteria or disclosure of the source of the criteria	ITAF
A statement that the audit engagement has been conducted in accordance with ISACA IS audit and assurance standards or other applicable professional standards	ITAF
Further explanatory details about the variables that affect the assurance provided	ITAF
Findings, conclusions and recommendations for corrective action including management's response	ITAF
Auditor reply	*IS Audit Reporting*
A paragraph stating that because of the inherent limitations of any internal control, misstatements due to errors or fraud may occur and go undetected	ITAF
A summary of the (audit) work performed	ITAF
An expression of opinion about whether, in all material respects, the design and/or operation of control procedures in relation to the area of activity were effective	ITAF
Executive summary	*IS Audit Reporting*
Where appropriate, references to any other separate reports that should be considered	ITAF
Date of issuance of the audit engagement report. In most instances, the date of the report is based upon the issue date.	ITAF
Names of individuals or entity responsible for the report	ITAF
Appendix	*IS Audit Reporting*

Phase 4 – Follow up

Management implements recommendations and takes measures

IT-auditor monitors process and assesses effectiveness of measures

Key Auditor questions (1/2)

1. Governance, Program Management & Decision Making

- What formal governance structure is in place for HR Next (steering committee, RACI, escalation paths)?
- How are roles and responsibilities divided between the Bank and Alight in the mirrored project structure?
- Has the bank performed a formal vendor risk assessment on Alight, SAP, UKG (PeopleDoc), Benify, Concur?
- Given the two-year preparation period, what stage-gates or maturity assessments were completed?
- How are decisions documented and approved (e.g., change of scope, introduction of SaaS add-ons)?

2. Project Scope & Timeline (Migration by July 2026)

- Is the July 2026 go-live date mandatory (e.g., legal/contractual) or flexible?
- What are the critical path items that may delay go-live?
- What contingency plans exist if the Visma Raet contract ends earlier or if Alight misses milestones?
- Is the scope fully defined, including all add-ons (PeopleDoc, Benify, Concur)?

3. Data Migration & Data Quality

- What is the data migration strategy, including mapping, cleansing, validation, and reconciliation?
- Who is accountable for data quality: the bank, Alight, or jointly?
- What test cycles (e.g., parallel payroll runs) will verify correctness before go-live?
- How will historical data from Visma Raet be preserved—extracted, archived, or migrated?

4. Security, Privacy & Compliance (GDPR, HR data = sensitive data)

- Have Data Processing Agreements (DPAs) been signed with all SaaS vendors (SAP, Alight, UKG, Benify, Concur)?
- What security certifications or SOC reports exist for each vendor, and how are gaps handled (Benify & Concur have no SOC reports)?
- How is access managed across multiple SaaS systems—what IAM model will be used (SSO promised by Alight)?
- What are the data residency locations for each SaaS provider?
- How will incident response between multiple vendors be coordinated?

Key Auditor questions (2x/2)

5. System Integration & Architecture (Slide 14)

- Who is responsible for integrating SAP systems with DIAL, Equens, SAP Accounting: Bank vs. Alight?
- Are interface specifications signed off?
- How will authentication work across SaaS add-ons?
- What testing (functional, regression, performance, interface, security) is in-scope?

6. Outsourcing & Third-Party Risk

- How does the bank monitor Alight's performance (SLAs, KPIs, audit rights)?
- What subcontractors does Alight use?
- How is the contractual clause about AI usage only with explicit approval monitored?
- What happens if Alight or any SaaS vendor fails a control in their SOC2?

7. Payroll Accuracy, Controls & Continuity

- How will the bank ensure payroll controls are correctly designed and configured in SAP Employee Central Payroll?
- Will payroll parallel runs be performed and with what acceptance threshold?
- What continuity plans and fallback payroll mechanisms exist?

Preliminary findings (1/2)

Finding 1 — Lack of assurance reports for several critical SaaS systems

- Benify: no SOC reports
- PeopleDoc: only pentest summaries
- Concur: no SOC or pentest reports
- **Impact:** Reduced ability to rely on vendor controls → bank must perform compensating controls.

Finding 2 — High dependency on Alight for operational control

Alight provides most services and operates the SAP systems.This introduces substantial concentration risk.

Impact: Outsourcing risk + reduced transparency + high dependency on a single provider.

Finding 3 — Complex system landscape with many integrations

Between SAP Employee Central, Payroll, Time Off, DIAL, Equens, SAP Accounting, PeopleDoc, Benify, Concur.

Impact: Integration failures may disrupt payroll, benefits, and compliance reporting.

Finding 4 — No mention of formal data migration control framework

Slides don't describe:

- data cleansing
- data validation
- reconciliation controls

Impact: Payroll errors, incorrect employee data, compliance penalties.

Preliminary findings (2/2)

Finding 5 — Unclear control ownership across Bank vs. Alight

- Mirrored teams create role ambiguity unless RACI is well defined.

Impact: Gaps in responsibility for data quality, access control, incident management.

Finding 6 — SaaS landscape introduces GDPR and data residency risks

Multiple systems store sensitive personal data (PeopleDoc, Benify, SAP, Concur).

Impact: High risk of non-compliance, fragmented controls.

Finding 7 — Program timeline is ambitious (go-live 1 July 2026)

Given:

- two years of prep
- many vendors
- multiple integrations

Impact: High risk of delay or quality tradeoffs.

Key Risks (1/2)

1. Payroll inaccuracies due to data migration or misconfigured payroll engine
High-impact: impacts all employee payments.

2. Third-party risk exposure due to lack of SOC2 reports
Benify, PeopleDoc, Concur → insufficient assurance.

3. Integration risks causing failed payments, reporting errors, or broken processes
Especially DIAL, Equens CPS, SAP Accounting.

4. GDPR compliance risk
Sensitive HR data in multiple SaaS environments without assurance and unclear data residency.

5. Vendor lock-in & dependency risk
Alight runs almost everything → single point of failure.

6. Operational risk during transition from Visma Raet
Contract ends June 2026 → tight cutover window.
No fallback described.

7. Insufficient oversight of AI usage
Contractual requirement needs monitoring processes; none described.

Tutorial week 6

Audit assessment – AI Agent AssistAI (answer to case 1)

Assignment 1: Define **Audit Objective**

1.Scope: The audit should focus on the data that is processed in the AssistAI.
2. Quality criteria: most focus should be on the integrity and confidentiality of that data
3 Audit standards: could include FinTrust Bank standards or external standards (NIST, ISO27001), both generic information security standards, with additional specific standards on AI.

Assignment 2: Identify **Key Controls**

1. Ensure the AI agent only accesses data that users are authorized to access.
2. Ensure privileged service accounts and integrations are properly controlled. (Access control and least privilege for the AI service identity.)
3. Ensure AI interactions and actions are logged and auditable.
4. Data protection controls (data classification, DLP, restricted repositories).
5. AI security guardrails such as prompt filtering and output validation.
6. Education to staff about the necessity to review output before using it, and that it is forbidden to use AI output to customers (without thorough review).

Assignment 3: Design Audit **Procedures**
1. Review access permissions of the AI agent and connected systems.
2. **Test** prompt manipulation to assess whether sensitive information can be extracted.
3. Review logging and monitoring of AI prompts, outputs, and automated actions.
4. Review awareness/communication procedures to users of AI assistant

Assignment 4: Recommend **Improvements**
1. Implement strong governance and risk assessment for AI deployments.
2. Introduce human oversight for high-risk AI outputs or actions.
3. Improve logging, monitoring, and incident response for AI activity.

Audit Assessment – Agentic AI AutoPilot (answer to case 2)

Assignment 1: Define Audit **Objective**

Scope: The audit should focus on the data that is processed in the AutoPilot.
Quality criteria: most focus should be on the integrity and confidentiality of that data
Audit standards: could include FinTrust Bank standards or external standards (NIST, ISO27001), both generic information security standards, with additional specific standards on AI. The standards should include controls for agentic AI.

Assignment 2: Identify **Governance & Security Controls**

1. Human-in-the-loop approval controls for critical actions (e.g., updating records, closing tickets, customer communication).
2. Access governance and data protection controls across integrated systems.
3. AI governance framework including monitoring, risk assessments, and usage policies.

4. Ensure autonomous AI actions are properly controlled and approved for high-risk activities.
5. Ensure data accessed across multiple systems is authorized and protected.
6. Ensure AI decisions and actions are transparent, traceable, and auditable.

Assignment 3: Design Audit **Procedures**
1. Review permissions and integrations between the AI agent and connected systems.
2. Test autonomous workflows to see whether incorrect actions can occur without approval.
3. Review system logs and decision traces to verify accountability of AI actions.
4. Sample outcomes of actions of AI Autopilot and review:: (a) to what extent they matched with the objective formulated by FinBank's staff members (b) to which extent customer communication only includes data related to that customer, and to this case.(c) to which extent the decisions taken (e.g. for a refund) can be traced back to accountable staff members.
5. Investigate incidents related to AI AutoPIlot and determine whether they are caused by insufficient controls.

Assignment 4: Recommend **Improvements**
1. Implement strong governance for agentic AI deployments (risk assessments, policies).
2. Introduce human oversight for sensitive or high-impact automated actions.
3. Improve monitoring, logging, and fail-safe mechanisms to prevent runaway automation.